

SICUREZZA DELLE RETI: ARCHITETTURA DMZ CON ACL ESTESE

1. Introduzione Concettuale alla DMZ

Nel campo della sicurezza informatica perimetrica, una **DMZ (Demilitarized Zone)**, o zona demilitarizzata, rappresenta un segmento di rete isolato interposto tra una rete privata locale (LAN interna), intrinsecamente considerata sicura, e una rete pubblica esterna (Internet), considerata per definizione non sicura.

La finalità logica della DMZ è consentire l'accesso pubblico a determinati servizi aziendali essenziali (come server web, server email o proxy) senza esporre direttamente la LAN interna a potenziali minacce esterne. Se un attaccante riesce a compromettere un server situato nella DMZ, la segmentazione e i sistemi di filtraggio impediscono l'estensione dell'attacco (movimento laterale) verso i sistemi critici della rete interna.

2. Lo Strumento di Controllo: ACL Estese

Per blindare la DMZ e regolare i flussi di traffico in base al principio del **privilegio minimo**, si utilizzano le **ACL (Access Control List) Estese**. A differenza delle ACL Standard (che filtrano il traffico basandosi esclusivamente sull'indirizzo IP di origine), le ACL Estese permettono un controllo granulare analizzando:

- **Indirizzo IP di Origine e Destinazione:** Chi sta parlando e con chi.
- **Protocollo di Trasporto:** TCP, UDP, ICMP, ecc.
- **Porte di Origine e Destinazione:** Identificazione dello specifico servizio (es. porta 80/443 per HTTP/S, porta 3306 per MySQL).
- **Stato della Sessione:** Tramite il flag `established` (in ambito Cisco), per consentire il passaggio del solo traffico di risposta a sessioni già legittimamente avviate dall'interno.

3. Scenario Pratico e Comune: Il Portale Web Aziendale

Per comprendere l'applicazione pratica, ipotizziamo uno scenario aziendale classico: l'azienda *"TechSoluzioni S.r.l."* possiede un'infrastruttura di rete protetta da un firewall centralizzato a tre interfacce (architettura DMZ "a tre zampe" o *Triple-Homed Firewall*).

Componenti dello Scenario:

- **Internet (Rete Esterna):** Accesso pubblico universale.
- **LAN Interna (Sottorete 10.0.1.0/24):** Dove risiedono le postazioni di lavoro dei dipendenti e i server gestionali interni.
- **DMZ (Sottorete 192.168.10.0/24):** Dove è ospitato il server web pubblico dell'azienda (IP: 192.168.10.80).
- **Database Server (IP: 10.0.1.250):** Situato all'interno della LAN protetta, contiene i dati sensibili usati dall'applicazione web.

Requisiti Logici di Sicurezza (Politiche di Accesso):

1. Gli utenti da Internet devono poter accedere al Server Web in DMZ esclusivamente tramite protocollo sicuro HTTPS (porta 443).
2. Il Server Web in DMZ deve poter interrogare il Database Server situato nella LAN interna solo sulla porta specifica del DBMS (MySQL, porta 3306). Al Server Web è rigorosamente vietato l'accesso a qualsiasi altra risorsa della LAN.
3. Gli amministratori di rete dalla LAN interna (sottorete 10.0.1.0/24) devono poter accedere al Server Web in DMZ via SSH (porta 22) per manutenzione.
4. Qualsiasi altro traffico non esplicitamente autorizzato deve essere bloccato (regola del *Deny All* implicito).

4. Schema Logico dei Flussi

I vettori di comunicazione ammessi possono essere sintetizzati nella seguente matrice di transito, implementata sul firewall per mezzo delle ACL Estese:

ORIGINE (SORGENTE)	DESTINAZIONE	PROTOCOLLO	PORTA DEST.	AZIONE / SCOPO
Any (Internet)	192.168.10.80 (Web Server)	TCP	443 (HTTPS)	PERMIT - Accesso pubblico al sito
10.0.1.0/24 (LAN)	192.168.10.80 (Web Server)	TCP	22 (SSH)	PERMIT - Amministrazione remota
192.168.10.80 (Web Server)	10.0.1.250 (DB Server)	TCP	3306 (MySQL)	PERMIT - Query dell'applicazione
Any	Any	Any	Any	DENY - Blocco di sicurezza predefinito

5. Implementazione Tecnica (Sintassi ACL Cisco-Style)

Di seguito viene presentata la configurazione logica delle ACL estese da applicare sulle rispettive interfacce del firewall per materializzare lo schema sopra descritto.

A. ACL applicata sull'interfaccia Esterna (Internet Ingress)

Questa lista controlla il traffico che entra dall'esterno diretto verso la DMZ.

```
ip access-list extended OUTSIDE_TO_DMZ
! Permette traffico HTTPS da chiunque verso il Web Server
permit tcp any host 192.168.10.80 eq 443
! Consente il traffico di ritorno per le connessioni iniziate dalla DMZ (se necessarie)
permit tcp any host 192.168.10.80 established
! Deny implicito alla fine
```

B. ACL applicata sull'interfaccia DMZ (DMZ Egress/Ingress Control)

Questa lista è fondamentale: impedisce al server DMZ (qualora venisse bucato) di scansionare o attaccare la LAN interna, consentendogli solo di dialogare con il Database.

```
ip access-list extended DMZ_TO_INTERNAL
! Permette al solo Web Server di interrogare il DB Server sulla porta 3306
permit tcp host 192.168.10.80 host 10.0.1.250 eq 3306
! Blocca tassativamente qualsiasi altro tentativo della DMZ di raggiungere la LAN
deny ip 192.168.10.0 0.0.0.255 10.0.1.0 0.0.0.255
! Permette alla DMZ di rispondere alle richieste SSH precedentemente avviate dalla LAN
permit tcp 192.168.10.0 0.0.0.255 10.0.1.0 0.0.0.255 established
! Permette alla DMZ di uscire su internet solo per aggiornamenti (es. HTTP/HTTPS)
permit tcp host 192.168.10.80 any eq 8443
deny ip any any
```

6. Considerazioni sulla Sicurezza e Analisi dei Rischi

L'efficacia di questo modello risiede nella rigidità delle regole. Se un utente malintenzionato sfruttasse una vulnerabilità applicativa del codice PHP/Node.js sul Web Server (ottenendo una shell remota sul server in DMZ), l'attaccante si troverebbe comunque "confinato" all'interno della sottorete [192.168.10.0/24](#).

I tentativi di pivoting o network scanning verso l'infrastruttura core dell'azienda (es. controller di dominio o PC dei dipendenti sulla [10.0.1.0/24](#)) verrebbero immediatamente intercettati e scartati dall'ACL della DMZ sulla base della regola esplicita di `deny`. L'unico vettore esposto rimane la porta 3306 del Database Server; per questo motivo, sul DB Server stesso dovranno essere attive politiche di hardening rigorose (es. credenziali di accesso complesse, patch aggiornate e vincolo di ascolto sul solo IP del Web Server).